ALEPH 과제 8 · 카드 2 — 남길 것

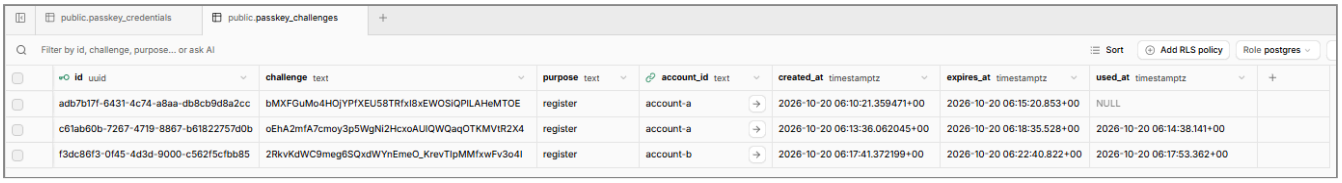
확인 주소: https://aleph-about-me-page-passkey.vercel.app/ · 확인 시각(KST): 2026-10-20 15:06~15:20 · 확인한 사람: 본인 (일반 Chrome 창에서 직접 등록)

이 문서의 내용은 모두 과제용으로 만든 것이며, 실제 개인정보와 비밀값은 없습니다. 패스키 저장 창에 보이는 계정 이메일은 담지 않았습니다.

1. 등록이 이뤄지는 순서

- ① **질문 요청**: 브라우저가 서버에 "계정 A에 패스키를 만들고 싶다"고 알리면, 서버가 **일회용 질문(challenge)**을 새로 만들어 DB에 보관하고 브라우저에 줍니다. (POST /api/passkey/register-options)
- ② **기기가 답함**: 기기가 질문에 답하면서 **열쇠 한 쌍을 만듭니다.** 개인키는 기기(Google 비밀번호 관리자)에 남고, 공개키와 서명만 서버로 갑니다.
- ③ **서버 확인·저장**: 서버는 돌아온 질문이 자기가 낸 값인지, 아직 안 쓴 것인지, 이 사이트용인지 확인한 뒤 **공개키만** 저장합니다. 질문은 그 순간 "사용됨"이 되어 다시 못 씁니다. (POST /api/passkey/register-verify)

2. 서버가 낸 질문과 보관 (C19, C20)



public.passkey_credentials | public.passkey_challenges

Filter by id, challenge, purpose... or ask AI — Sort — Add RLS policy — Role postgres

id uuid	challenge text	purpose text	account_id text	created_at timestamptz	expires_at timestamptz	used_at timestamptz
adb7b17f-6431-4c74-a8aa-db8cb9d8a2cc	bMXFGuMo4HOjYPfXEU58TRfxI8xEWOSiQPILAHeMTOE	register	account-a	2026-10-20 06:10:21.359471+00	2026-10-20 06:15:20.853+00	NULL
c61ab60b-7267-4719-8867-b61822757d0b	oEhA2mfA7cmoy3p5WgNi2HcxoAUlQWQaqOTKMVtR2X4	register	account-a	2026-10-20 06:13:36.062045+00	2026-10-20 06:18:35.528+00	2026-10-20 06:14:38.141+00
f3dc86f3-0f45-4d3d-9000-c562f5cfbb85	2RkvKdWC9meg6SQxdWYnEmeO_KrevTlpMMfxwFv3o4I	register	account-b	2026-10-20 06:17:41.372199+00	2026-10-20 06:22:40.822+00	2026-10-20 06:17:53.362+00

DB 표 passkey_challenges(Supabase, 서버만 읽을 수 있는 표)입니다. 세 번의 요청에 질문이 **모두 다른 값**입니다. 쓴 두 건(계정 A 등록, 계정 B 등록)은 used_at에 시각이 찍혀 다시 못 쓰고, 맨 위 한 건(취소한 시도)은 NULL이라 쓰이지 않았습니다. 질문은 만든 뒤 5분이 지나면(expires_at) 못 씁니다.

3. 등록 결과와 서버에 저장된 값 (C21, C22, C24)



id	account_id	credential_id	public_key	counter	transports	name	created_at
2f5f9c1a-a9d1-490c-addd-3ecc28fa1482	account-b	GUC1V99IWv_RkIAp-X5nPA	MFkwEwYHKoZIzj0CAQYIKoZIzj0DAQcDQgAEThhpP86N04dLS2OoufBH	0	["hybrid","internal"]	B 1st passkey	2026-10-20 06:17:55.857546+00
382a23be-627c-44ed-a067-4f1817239863	account-a	2hA0sIVGMQz6mb_zAr5IyQ	MFkwEwYHKoZIzj0CAQYIKoZIzj0DAQcDQgAE4-aEn0p28QWmjhiqFRK01	0	["hybrid","internal"]	A 1st passkey	2026-10-20 06:14:40.324645+00

DB 표 passkey_credentials: 계정 A와 B에 각각 이름 붙은 패스키가 1건씩 저장됐습니다.

저장된 열	뜻
account_id	어느 계정의 패스키인지 (account-a, account-b)
name	사람이 알아볼 이름 (**A 1st passkey**, **B 1st passkey**)
credential_id	패스키 식별값(공개 정보)
public_key	**공개키**(ES256, P-256). 서명이 맞는지 확인하는 데만 쓰이며, 이것으로 로그인할 수는 없습니다. 비밀번호가 아닙니다.
counter, transports, created_at	서명 횟수, 연결 방식, 등록 날짜

비밀번호 열도, 개인키 열도 없습니다. 개인키는 서버로 오지 않기 때문입니다.



계정 A 등록 직후 화면: 서버가 저장했다고 돌려준 값이 그대로 보이고, 위 DB 표의 값(식별값 2hA0sIVGMQz6mb_zAr5IyQ, 공개키 MFkwEwYH…)과 같습니다.



계정 B 등록 직후 화면(식별값 GUC1V99lWv_RklAp-X5nPA).

4. 개인키가 서버로 전송되지 않는다 (C23) — 계정 B 등록의 요청·응답 기록

화면의 “요청·응답 기록”에서 복사한 글입니다. 두 번째 단계의 **요청 본문**에 있는 항목은 id, rawId, type, response(clientDataJSON, attestationObject, transports) 뿐입니다. 이 중 어느 것에도 개인키는 들어 있지 않습니다. 긴 값은 앞부분과 글자 수만 줄여 보여 주도록 만들었고(질문 challenge는 전부 보임), 개인키가 들어갈 항목 자체가 없습니다.


```
[
 {
  "단계": "1. 질문 요청 → 응답 200",
  "시각": "오후 3:17:37",
  "요청": {
   "accountId": "account-b",
   "name": "B 1st passkey"
  },
  "응답": {
   "challenge": "2RkvKdWC9meg6SQxdWYnEmeO_KrevTIpMMfxwFv3o4I",
   "rp": {
    "name": "ALEPH 소개 페이지",
    "id": "aleph-about-me-page-passkey.vercel.app"
   },
   "user": {
    "id": "YWNjb3VudC1i",
    "name": "account-b",
    "displayName": "계정 B (커피)"
   },
   "pubKeyCredParams": [
    {
     "type": "public-key",
     "alg": -7
    },
    {
     "type": "public-key",
     "alg": -257
    },
    {
     "type": "public-key",
     "alg": -8
    }
   ],
   "timeout": 60000,
   "attestation": "none",
   "excludeCredentials": [],
   "authenticatorSelection": {
    "residentKey": "required",
    "requireResidentKey": true,
    "userVerification": "preferred"
   }
  }
 },
 {
  "단계": "2. 기기의 답 전송 → 응답 201",
  "시각": "오후 3:17:52",
  "요청": {
   "name": "B 1st passkey",
   "credential": {
    "id": "GUC1V99lWv_RklAp-X5nPA",
    "rawId": "GUC1V99lWv_RklAp-X5nPA",
    "type": "public-key",
    "response": {
     "clientDataJSON": "eyJ0eXBlIjoid2ViYXV0aG4uY3Jl…(216자)",
     "attestationObject": "o2NmbXRkbm9uZWdhdHRTdG10oGhh…(238자)",
     "transports": [
      "hybrid",
      "internal"
     ]
    }
   }
  },
```

```
  "응답": {
   "ok": true,
   "account": {
    "id": "account-b",
    "label": "계정 B (커피)"
   },
   "stored": {
    "name": "B 1st passkey",
    "created_at": "2026-10-20T06:17:55.857546+00:00",
    "credential_id": "GUC1V99lWv_RklAp-X5nPA",
    "public_key": "MFkwEwYHKoZIzj0CAQYIKoZIzj0D…(122자)",
    "algorithm": "ES256 (P-256)",
    "counter": 0
   },
   "note": "서버에는 위 공개키만 저장됩니다. 개인키는 이 기기…(47자)"
  }
 }
]
```


> 추가 점검: 개발 환경에서 가상 인증기로 같은 흐름을 돌려, 인증기가 가진 **개인키 값이 오간 모든 요청·응답 본문 어디에도 없음**을 확인했습니다. 같은 점검 20/20개가 통과했습니다(질문 재사용 거절, 출처 변조 거절, 취소 시 저장 0건 포함). 결과: evidence/card2/local-test-results.json

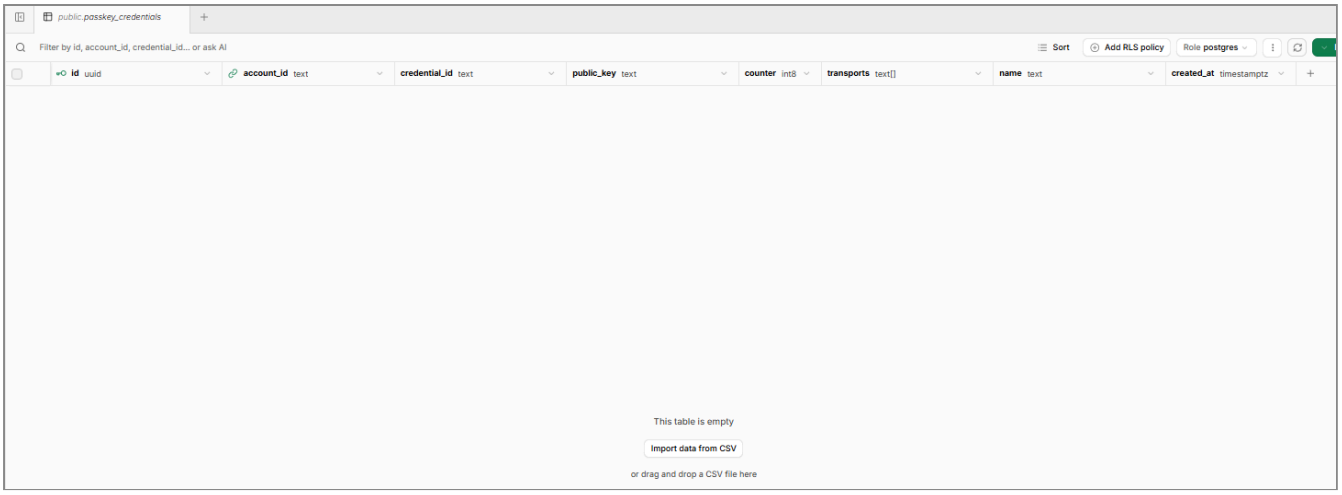
5. 도중에 취소하면 (C25)

패스키 저장 창에서 **취소**를 눌렀을 때의 기록입니다. 서버로 아무것도 보내지 않았고, 화면에는 “취소했습니다. 서버에는 아무것도 저장되지 않았습니다.”가 나왔습니다.


```
[
 {
  "단계": "1. 질문 요청 → 응답 500",
  "시각": "오후 3:06:57",
  "요청": {
   "accountId": "account-a",
   "name": "취소 테스트"
  },
  "응답": {
   "error": "server_error",
   "message": "서버에서 처리하지 못했습니다."
  }
 },
 {
  "단계": "1. 질문 요청 → 응답 200",
  "시각": "오후 3:10:17",
  "요청": {
   "accountId": "account-a",
   "name": "취소 테스트"
  },
  "응답": {
   "challenge": "bMXFGuMo4HOjYPfXEU58TRfxI8xEWOSiQPlLAHeMTOE",
   "rp": {
    "name": "ALEPH 소개 페이지",
    "id": "aleph-about-me-page-passkey.vercel.app"
   },
   "user": {
    "id": "YWNjb3VudC1h",
    "name": "account-a",
    "displayName": "계정 A (보안·네트워크)"
   },
   "pubKeyCredParams": [
    {
     "type": "public-key",
     "alg": -7
    },
    {
     "type": "public-key",
     "alg": -257
    },
    {
     "type": "public-key",
     "alg": -8
    }
   ],
   "timeout": 60000,
   "attestation": "none",
   "excludeCredentials": [],
   "authenticatorSelection": {
    "residentKey": "required",
    "requireResidentKey": true,
    "userVerification": "preferred"
   }
  }
 },
 {
  "단계": "2. 기기 단계",
  "시각": "오후 3:10:41",
  "결과": "NotAllowedError (서버로 아무것도 보내지 않음)"
 }
]
```


첫 줄의 응답 500은 이 증거를 만들던 중 실제로 있었던 서버 오류입니다. 원인은 DB 표에 서버 키의 사용 권한이 없던 것이었고(서버 로그: `db GET passkey_accounts -> 403`), SQL로 서버 키에만 권한을 주어 고쳤습니다(저장소 db/schema.sql, 커밋 02b913b). 고친 뒤

3시 10분의 두 번째 줄부터 정상입니다.



취소 직후(등록 전)의 passkey_credentials: **0건**("This table is empty"). 취소로 저장된 것이 없습니다. 같은 시각 passkey_challenges에는 서버가 낸 질문만 1건 남아 있었고 used_at은 NULL이었습니다.

6. 패스키를 저장한 곳 (C26)

개인키	이 PC의 Chrome이 **Google 비밀번호 관리자**에 저장했습니다("패스키 저장됨 — Google 비밀번호 관리자에 저장된 패스키"). 이 사이트의 서버, Vercel, Supabase에는 없습니다.
공개키	Supabase 프로젝트 `t08-about-me-page-passkey`의 `passkey_credentials` 표. 서버 키로만 읽고 쓸 수 있습니다.
저장 위치 고르는 창	저장 위치로 "Google 비밀번호 관리자"와 "휴대전화·태블릿 또는 보안 키" 중에서 고를 수 있었고, 앞의 것을 골랐습니다.

7. 로그인하지 않은 사람은 남의 계정에 패스키를 붙일 수 없다



패스키가 이미 있는 계정 A에, 로그인하지 않은 채 "추가시도"라는 이름으로 등록을 시도하자 서버가 거절했습니다(403, "이미 패스키가 있는 계정입니다. 로그인한 뒤에 추가해야 합니다."). 패스키 창은 뜨지 않았고 저장된 것도 늘지 않았습니다.

8. 카드 2 통과 기준 대응

번호	기준	결과	근거
C19	서버가 등록용 질문(challenge)을 만들어 보내고, 확인할 때까지 보관한다	**통과**	2절: 응답에 질문이 오고, 같은 값이 DB 표 passkey_challenges에 보관됨
C20	등록 요청마다 질문 값이 서로 다르다는 기록이 있다	**통과**	2절: 세 번의 요청이 서로 다른 질문(bMXFGuMo4H… / oEhA2mfA7c… / 2RkvKdWC9m…)
C21	등록이 끝나면 서버에 공개키가 저장된다	**통과**	3절: passkey_credentials에 계정 A, B 각 1건(공개키)
C22	서버에 저장된 값이 있고, 그 값이 공개키이며 비밀번호가 아니라는 설명이 있다	**통과**	3절: 저장된 열과 설명(공개키 값, 비밀번호·개인키 열 없음)
C23	개인키가 서버로 전송되지 않는다는 사실이 등록 요청 본문 기록으로 확인된다	**통과**	4절: 요청 본문 항목 6개(개인키 없음), 개인키는 기기에 남음
C24	등록한 패스키에 사람이 알아볼 수 있는 이름이 붙는다	**통과**	3절: `A 1st passkey`, `B 1st passkey`
C25	등록 도중 취소하면 화면에 안내가 나오고 서버에 아무것도 저장되지 않는다	**통과**	5절: 취소 안내 화면·기록, 취소 직후 passkey_credentials 0건
C26	패스키를 저장한 곳이 어디인지가 제출문에 적혀 있다	**통과**	6절: Google 비밀번호 관리자(기기 쪽), 서버에는 공개키만

> **이 문서의 범위**: 등록까지입니다. 로그인(카드 3)과 패스키 목록 화면(카드 4)은 아직 구현 전이라, 남길 것 중 “패스키 목록 화면”은 지금은 DB 표 화면(3절)으로 대신하고 로그인 구현 뒤 화면을 추가합니다. 서버 확인 코드는 외부 라이브러리 없이 Node.js 내장 crypto로 직접 구현했습니다(api/_lib/webauthn.js).